

Installed, Launched, Probed: An Execution-Based Conformance Census of the Model Context Protocol Registry

Anonymous Author(s)

Abstract—The Model Context Protocol (MCP) connects LLM agents to external tools, and public registries now list tens of thousands of MCP servers. Most empirical studies of this ecosystem are *static*: they scan source code, mine issue trackers, or read registry metadata. None calls the tools of registry servers at scale to check whether the servers start and follow the protocol. This paper does. From the official registry (17,432 unique servers) we run a complete census of all 6,106 self-contained, locally-installable servers. Each is launched in an isolated sandbox and driven through a conformance harness that checks the initialization lifecycle, tool listing and declared-schema validity, and how the server handles an unknown tool name, a wrong-typed argument and a malformed protocol frame. Only 61.1% (95% CI 59.8–62.3) of installable servers start and complete a handshake. 88.4% (95% CI 87.3–89.4) of responding servers report an unknown tool the same way, which differs from the error reporting the specification illustrates. We trace this to SDK defaults, and an open specification proposal would make it the specified behavior. 3.5% (95% CI 3.0–4.1) execute a tool on an argument their own declared schema rejects and return a well-formed result that a client cannot tell apart from a correct answer, although the specification requires servers to validate all tool inputs. Both behaviors trace back to the SDKs, so they can be measured and fixed there. We release the harness and the disclosure-filtered dataset.

I. INTRODUCTION

Large language model agents act through external tools, and the Model Context Protocol (MCP) is the dominant standard for connecting them. In under two years MCP went from one vendor’s proposal to an ecosystem whose public registries list tens of thousands of servers; the official registry alone contains 17,432 unique servers at the time of our study. When a server fails to start, accepts ill-typed arguments or returns a malformed result, the agent calling it can act on wrong output without knowing it. Every agent built on MCP inherits the reliability of this server layer.

Most published empirical studies of the MCP ecosystem examine servers *without running them*, and those that do run them look for vulnerabilities. Existing work scans source code and metadata for health and maintainability, crawls registries to characterize scale and supply-chain structure, or mines GitHub issues to build fault taxonomies. None of it answers a simpler question: *if you install these servers and speak the protocol to them, do they start, and do they follow the specification?* The protocol maintainers ship a conformance test suite, but it is built for SDK maintainers to run in continuous integration, and we know of no use of it on the

deployed ecosystem. It tests the SDKs, not the seventeen thousand servers built on them.

We ran that measurement. Starting from the official registry, we census every self-contained, locally-installable server, launch each in an isolated sandbox, and drive it through a conformance harness. The harness checks the initialization lifecycle, tool listing and declared-schema validity, and three inputs that come up in ordinary agent sessions: a call to an unknown tool, a call with a wrong-typed argument, and a malformed protocol frame. Each server is graded against the protocol version it negotiates. Requirements stated with an RFC-2119 keyword (MUST/SHOULD) are graded apart from behavior the specification only shows in an example.

Only 61.1% (95% CI 59.8–62.3) of installable servers start and complete a protocol handshake. The rest fail in ways we classify into a startup-failure taxonomy, from install errors to silent exits to hangs. Among servers that do respond, 88.4% (95% CI 87.3–89.4) report a call to a non-existent tool as a “successful” tool-execution error (`isError: true`) instead of the JSON-RPC protocol error the specification illustrates. We trace this divergence to the default behavior of the official SDKs, which is inherited by the servers built on them. An open proposal would reclassify unknown-tool failures to match what the SDKs already do [1], and our census measures how much of the ecosystem already behaves that way. Separately, 3.5% (95% CI 3.0–4.1) of responding servers execute a tool on an argument their own declared schema rejects and return a well-formed result. In one case a code-scanning tool asked to scan an integer replied `CLEAN`, with neither an error code nor an `isError` flag a client could act on. This behavior violates the specification’s requirement that servers validate all tool inputs. A further 0.5% (95% CI 0.3–0.7) fail to recover from a malformed frame and answer nothing further, although JSON-RPC 2.0 requires a reply to every request.

We organize the study around five research questions:

- **RQ1 (Runnability).** What fraction of registry-published servers can a client install and start, and when they do not start, why not?
- **RQ2 (Lifecycle conformance).** Of the servers that respond, how many correctly implement the initialization lifecycle, tool listing, and declared-schema validity?
- **RQ3 (Input enforcement).** How many servers execute a tool on an argument their own declared schema rejects, and what does the client receive when they do?

- **RQ4 (Specification versus practice).** Where the specification and deployed behavior disagree on error reporting, how large is the divergence, what causes it, and which side is moving?
- **RQ5 (Correlates).** Do runnability and conformance vary with the package registry a server ships on?

This paper makes four contributions:

- **A protocol-level conformance measurement of the MCP ecosystem by execution (C1):** prior ecosystem studies read code and metadata. We install every eligible server in the registry, speak the protocol to it, and test how it responds to inputs.
- **A two-dimensional taxonomy (C2)** of startup-failure classes and conformance-violation classes, each tied to a concrete agent-facing consequence.
- **A root-cause account of the spec–practice divergence (C3):** by attributing each server to its SDK, we show that the dominant divergence comes from defaults in the official SDKs.
- **Open infrastructure (C4):** a conformance harness that extends the official suite’s scenarios to arbitrary deployed servers, plus the released measurement dataset, so the census can be repeated and authors can check their own servers.

II. BACKGROUND AND RELATED WORK

A. The Model Context Protocol

MCP standardizes how LLM agents discover and invoke external tools. A client and server negotiate a protocol version and capabilities during an `initialize` handshake. The client can then list tools (`tools/list`) and invoke them (`tools/call`). Messages follow JSON-RPC 2.0, including its error-object semantics and its reserved error codes. Most deployments run the server locally over `stdio`, where `stdout` carries protocol traffic and nothing else. The specification is versioned by date, and servers may negotiate down to a version they support.

B. Static studies of the MCP ecosystem

The ecosystem has been studied at scale, but rarely by running it. Health-and-maintainability work analyzes source and metadata for roughly 1,900 servers using static scanners and code-smell detectors [2], while registry measurement crawls several marketplaces and characterizes scale, maintenance and supply-chain concentration across some 8,000 servers from marketplace data, without running them [3]. A companion dataset effort catalogues 3,238 candidate MCP repositories on GitHub and classifies them by operational role, again from repository evidence [4], and a parallel line studies the *application* side, characterizing how 1,723 MCP applications configure and supervise the servers they consume [5]. Fault taxonomies take a third route and mine GitHub issues [6, 7]. One finds tool faults and data-schema faults the two most frequent categories [6], the same two areas our harness tests directly. None of this work executes a server.

C. Execution-based work is security-focused

Some prior work does execute MCP servers, to find security problems. Sandboxed behavioral scanners hunt vulnerabilities in curated corpora [8], taint-style analyzers confirm exploitable flaws across tens of thousands of repositories [9], a security-invariants benchmark avoids live third-party execution altogether in favor of fixtures and a 40-repository metadata sample [10], and malicious-server detection, authentication studies, and dynamic assessment of internet-facing endpoints scope to security surfaces [11], [12], [13].

MCPZoo assembles 64,611 unique servers, of which more than 37,288 support dynamic analysis, and uses them to show that existing security scanners are unreliable, with fewer than half of sampled alerts holding up under manual validation [14]. That corpus differs from ours in two ways. First, MCPZoo is built by *repairing* servers: a multi-agent framework infers environments and iteratively fixes deployment and runtime defects so that in-the-wild repositories become running services. That construction is the right choice for studying what a server does once it runs, and it necessarily removes the signal we measure, which is how often a server runs at all when a client installs it as published. Second, its population is collected from multiple public markets, whereas ours is the official registry, the surface a client actually resolves against. That their corpus needed a repair framework fits our runnability finding. Conformance is a separate question: whether a server that is neither malicious nor vulnerable does what the specification says.

Concurrently with our work, Afsar draws a seeded random sample of 400 npm `stdio` servers from the same registry and probes each without repair: 48.8% complete a handshake, servers that never start (37.5%) outnumber those missing credentials (13.3%), and the 195 that run show no fatal schema violations across 2,766 tools [15]. That study samples one package ecosystem and checks declared structure. We census both npm and PyPI and test behavior, calling tools with inputs the server should reject.

D. The specification’s own error-handling debate

The categorization this paper measures is under active revision. SEP-1303, accepted and reflected in the current specification, moved tool input validation errors out of protocol errors and into tool execution errors, reasoning that a language model can self-correct only from an error that reaches its context [16]. SEP-2145, open at the time of writing, extends the same treatment to tool resolution failures, including unknown tools, and states its purpose as aligning the specification with existing Python and TypeScript SDK behavior [1]. We take no position on which mechanism is correct. We measure what fraction of the deployed ecosystem the proposed alignment already describes.

Concurrent with this work, a practitioner census posted to the same proposal probed roughly 10,500 *remote* registry endpoints, harvested their tool lists, and reported that 88.8% of mutating tools declare no output schema at all, arguing that the proposal’s output-validation clause is inert for most of the write surface [17]. That measurement and ours are close to

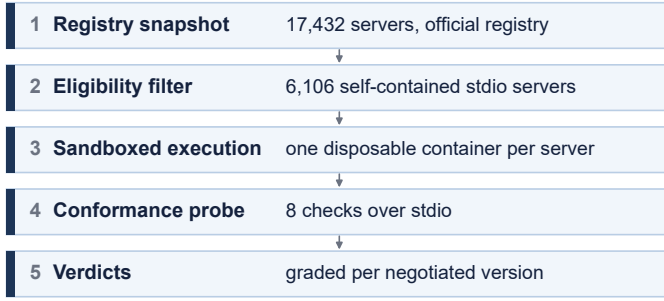


Fig. 1. Measurement pipeline. Every eligible server is installed and executed in its own disposable container, then driven through the conformance probe and graded against the protocol version it negotiates.

disjoint. It probes hosted HTTP endpoints and reads declared metadata, whereas we install and execute local stdio servers and test behavior against inputs. It addresses the output-validation clause, and we address tool resolution and input enforcement.

E. Conformance tooling and the gap we fill

The protocol maintainers ship a conformance suite for testing client and server implementations, built for SDK maintainers to run in continuous integration; to our knowledge it has not been used to measure the deployed ecosystem. As far as we know, ours is the first reproducible conformance measurement of this ecosystem that installs and executes the servers themselves and tests their behavior against adversarial inputs, released with an open harness and dataset.

III. METHODOLOGY

We measure the MCP server ecosystem by *executing* it. This section defines the sampling frame, the conformance harness, the sandbox, and the grading rules (Figure 1). The harness and the released dataset make every number reproducible.

A. Sampling frame

We crawl the official MCP registry (registry.modelcontextprotocol.io) via its cursor-paginated API, retaining the latest published version of each server. This yields 17,432 unique servers. Each server declares zero or more *packages* (installable artifacts on npm, PyPI, OCI, NuGet, or Cargo) and/or *remotes* (hosted HTTP endpoints). Our study population is the set of servers that are (i) locally installable, (ii) use the `stdio` transport, (iii) distributed on npm or PyPI (the two dominant registries), and (iv) *self-contained*: they declare no required environment variable or argument that lacks a default. Criterion (iv) restricts us to servers that a client could launch without provisioning secrets, which limits what mass execution can do to third-party systems and keeps the population reproducible. We report the exclusion of remote-only and credential-requiring servers explicitly (Section VI) and treat the resulting frame as the denominator for all rates. We probe the *entire* frame (all 6,106 eligible servers), so the measurement is a census of the eligible population.

B. Conformance harness

The harness, `mcpprobe`, is a minimal, hand-written JSON-RPC client speaking line-delimited messages over the server’s stdio. We do *not* use an official SDK client. To observe raw behavior, including responses to malformed frames, the probe must not inherit any SDK-side correction or validation. The harness offers protocol version 2025-06-18 at initialization (the then-current revision was 2025-11-25), records the version the server *negotiates*, and grades all later checks against that version. A server that supports the offered version must answer with it, and 3,576 of 3,685 responders did, so almost all grading is against 2025-06-18. Responding servers negotiated four distinct revisions, and 109 of them settled on something other than the version we offered, the oldest dating to 2024-11-05.

Each server is driven through the following checks, whose identifiers align with the categories of the official `modelcontextprotocol/conformance` suite where an analogue exists:

- **server-initialize**: the `initialize` request must return a result carrying a protocol version and a capabilities object; the harness then sends `notifications/initialized`.
- **ping**: a `ping` must return an empty-object result.
- **tools-list**: if the server advertises the tools capability, `tools/list` must return an array in which every entry has a name and an `inputSchema` object.
- **tools-schema-valid**: each declared `inputSchema` must be a valid JSON Schema (checked by meta-validation).
- **tools-call-unknown**: calling a non-existent tool must be rejected. The specification’s Error Handling section categorizes “Unknown tools” under *Protocol Errors* (standard JSON-RPC errors) and illustrates this with a `-32602` example, as opposed to *Tool Execution Errors* reported as a result with `isError: true`. This categorization is prose plus an example; it uses no RFC-2119 MUST/SHOULD keyword. We therefore do not treat a non-conforming response as a “violation”; instead we record which of the two mechanisms the server uses (see *error-as-result* below).
- **tools-call-invalid-args**: for a tool with a typed required property, calling it with a wrong-typed value should be rejected. The spec is itself ambiguous here, since it lists “Invalid arguments” under Protocol Errors but “Invalid input data” under Tool Execution Errors, so we count *either* a protocol error *or* an `isError` result as acceptable, and flag only a plain success response (the tool ran on ill-typed input) as a defect.
- **malformed-json**: after receiving a syntactically invalid frame, the server must not crash or hang; a subsequent `ping` must still succeed.
- **stdout-purity**: under the stdio transport, the server must emit only protocol messages on stdout; any non-JSON line is a channel-corruption defect.

C. Grading and the error-as-result category

Verdicts are `pass`, `fail`, `warn`, `skip`, and one category introduced by calibration: `error-as-result`. When validating the harness against the official reference servers (`server-memory`, `server-everything`), we found they answer an `unknown-tool` call not with the specified JSON-RPC `-32602` error but with a *successful* response whose `result.isError` flag is set. Because this behavior originates in the official SDKs and is therefore ecosystem-wide, we grade it as its own category, not as a failure, and report its prevalence as a result.

D. Sandbox

Each server runs in a fresh container (`node:22-slim` for `npm`, an `astral-sh/uv` image for `PyPI`) with a memory cap, a single CPU, a PID limit, `no-new-privileges`, all Linux capabilities dropped, and no host filesystem mounts. The harness supports two probe conditions. In the **two-phase** condition, an online install pass populates the cache and the conformance probe then runs with `--network=none`, so no server code has network access while it is being measured. In the **single-phase** condition, install and probe occur together in one ephemeral container and the network is available throughout. The census reported here was measured in the single-phase condition, for the operational reasons given in Section III-E, and we state the consequences for validity in Section VI.

E. Execution environment and probe condition

The census was executed on a single disposable cloud instance (no cloud credentials attached) using the online single-phase condition: install and probe occur in one ephemeral `--rm` container per server, with nothing cached between servers so that disk usage stays bounded across the full ecosystem; the recorded launch command of every run confirms that no volume was mounted. We did not run a controlled comparison of the two conditions. In development runs on smaller subsets, `error-as-result` prevalence (87%) and silent type non-enforcement (7%) among responding servers were the same under both conditions; handshake yields from those runs are not comparable, because the subsets differed. Two groups of runs ended for reasons outside the server’s control or of uncertain cause: 32 probes (0.5%) were killed (exit 137) by either the memory cap or an automated guard that reclaims host disk space, and the census does not record which; 17 probes (0.3%) aborted on a harness-side error before any check ran. All but one of these 49 are counted as non-handshaking, so they can only lower the handshake yield; the exception was killed after completing its handshake.

F. SDK-level confirmation

Where a conformance failure concentrates in one SDK family, the census alone cannot say whether the library permits the failure or the authors introduced it independently. For the input-validation result we tested the SDK directly. We build two minimal servers exposing one tool that declares a single

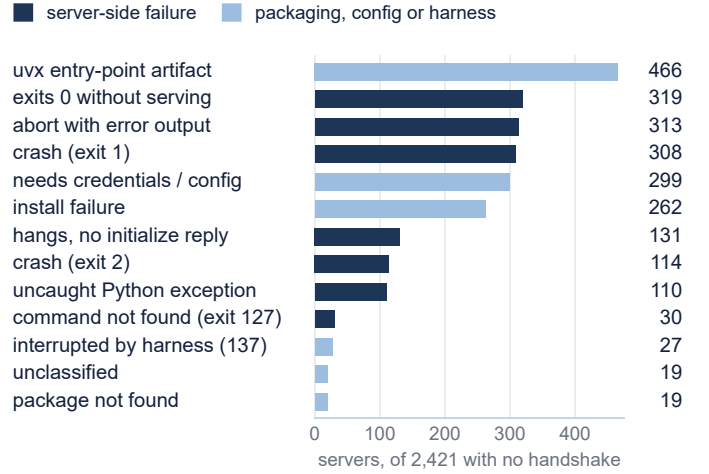


Fig. 2. Why servers never reach a handshake. Configuration requirements and the entry-point artifact are separated from genuine startup failures.

required string property, one using the low-level `Server` API and one using the high-level `McpServer` API, both on the same SDK release, and drive each with the same harness check used in the census: a `tools/call` carrying an integer where the declared schema requires a string. The construction is otherwise identical, so any difference in outcome is a property of the API path. We report the result in Section IV-C. The two servers and the probe script are released with the harness.

G. Funnel accounting

Whether a server runs at all is RQ1, so we count every stage: declared $\rightarrow$ eligible (self-contained `stdio` `npm/PyPI`) $\rightarrow$ container started $\rightarrow$ process launched $\rightarrow$ handshake completed $\rightarrow$ probed. Servers that never reach a handshake are classified into startup-failure categories (Section IV) from their exit code and `stderr`, so that the lost yield can be explained.

IV. RESULTS

We probed all 6,106 servers in the eligible frame.

A. RQ1: Runnability and the startup funnel

3,729 of 6,106 servers (61.1% (95% CI 59.8–62.3)) complete the MCP handshake once the entry-point artifact described in Section IV-E is corrected; the uncorrected census figure is 60.4% (95% CI 59.1–61.6). Roughly two in five never serve the protocol. Figure 2 classifies those failures by cause.

Servers that only need credentials or configuration are counted apart from servers that crash, since a missing setting is a documentation gap. Most failures happen *after* a successful install: the package downloads, then the process crashes, hangs, or exits without speaking the protocol. The failure is in the software, not the packaging. A concurrent random draw of 400 `npm` servers reports a 48.8% handshake rate [15], against 65.9% for the `npm` servers in our census. The two differ in snapshot and harness, so we do not read the gap as a trend.

TABLE I
STARTUP-FAILURE TAXONOMY: CAUSES FOR SERVERS THAT NEVER
REACH A HANDSHAKE.

Failure class	Count	% of failures
entrypoint-not-provided	466	19.2
exit-silent	319	13.2
crash-with-error-output	313	12.9
crash-exit-1	308	12.7
needs-auth-or-config	299	12.4
install-error	262	10.8
hang-no-reply	131	5.4
crash-exit-2	114	4.7
crash-python-exception	110	4.5
crash-exit-127	30	1.2
crash-exit-137	27	1.1
unclassified	19	0.8
install-not-found	19	0.8
crash-exit-255	1	0.0
crash-exit-3	1	0.0
crash-exit-4	1	0.0
crash-exit-254	1	0.0
Total non-handshaking	2421	100.0

TABLE II
VERDICT DISTRIBUTION PER CHECK OVER RESPONDING SERVERS, WITH
95% WILSON CIs ON THE PASS (OR DOCUMENTED) RATE.

Check	Pass	Fail	Other	Pass rate (95% CI)
server-initialize	3685	0	0	100.0 (99.9–100.0)
ping	3638	47	0	98.7 (98.3–99.0)
tools-list	3673	5	7	99.7 (99.4–99.8)
tools-schema-valid	3671	2	0	99.6 (99.4–99.8)
tools-call-unknown	139	166	3380	3.8 (3.2–4.4)
tools-call-invalid-args	3309	273	103	89.8 (88.8–90.7)
malformed-json	3668	17	0	99.5 (99.3–99.7)
stdout-purity	3654	31	0	99.2 (98.8–99.4)

B. RQ2–RQ3: Conformance and robustness

Table II reports the verdict distribution for each check over the 3,685 responding servers, with 95% Wilson confidence intervals. Lifecycle and tool-listing conformance are high, and the discriminating checks are error handling, argument type enforcement, and malformed-input survival. 7.4% (95% CI 6.6–8.3) of responders failed to reject a wrong-typed required argument, which Section IV-C decomposes into the servers that reported the problem anyway and the smaller class that did not. 0.5% (95% CI 0.3–0.7) failed to recover from a malformed frame. We report this as a robustness and conformance failure, not a security one. Under the stdio transport the client is the parent process and the only writer to the server’s standard input, so a party able to deliver a malformed frame can already terminate the subprocess directly. JSON-RPC 2.0, on which MCP is built, nonetheless defines a parse-error response for this case and requires a reply to every subsequent request [18], and these servers give neither. One maintainer who reproduced our finding made exactly this argument, and we adopt their characterization over our original one (Section VI).

129	118	26
executed the tool, no error signalled	problem reported in the result text	not classifiable

Fig. 3. The coarse verdict splits in half. Only the left segment is undetectable by the client: the tool ran on input its schema rejects and returned a well-formed result carrying no error indication.

C. RQ3 refined: what a failure to reject actually returns

The `tools-call-invalid-args` verdict records whether a server rejects an argument that violates its own declared schema. As a protocol judgment that is correct, but it cannot tell a client what it received, because two different behaviors produce the same verdict. A server may validate the input and report the problem in the result *text* without setting `isError`, which is non-conformant but leaves the information available. Or it may execute the tool and return ordinary-looking output, which does not. We separate the two by classifying the recorded response of every server in this category (Figure 3, Table III).

Of 273 such servers, 118 (43%) reported the problem in the result text, so the server noticed and a client willing to parse prose could too. 129 (47%) executed the tool and returned a result with no indication that anything was wrong. For 26 the response could not be classified from the transcript. The hazard class is therefore 3.5% (95% CI 3.0–4.1) of responding servers, smaller than the 7.4% (95% CI 6.6–8.3) of the raw verdict, and it is the figure we report. We count a server as reporting the problem whenever its output contains any error-like token, so 129 is a lower bound.

This is not a matter of interpretation. The specification’s security requirements state that servers **MUST** validate all tool inputs [19]. A server that executes a tool on an argument contradicting its own published schema has not validated that input, so these 129 servers fail an explicit RFC-2119 requirement, as do the servers that write non-protocol output to stdout, which the stdio transport forbids with a **MUST NOT**.

Here SDK attribution narrows the cause further than it does for the error-reporting divergence. 112 of the 129 are built on the official TypeScript SDK and 0 on either Python SDK, against responding populations of 2,347 and 1,020 respectively. A behavior absent from one language ecosystem and concentrated in another points to the library, so we tested the SDKs directly (Section III-F). On `@modelcontextprotocol/sdk 1.30.0`, the current release at the time of writing, a server built with the low-level `Server` API publishes an `inputSchema` in `tools/list` and the SDK then does not check `tools/call` arguments against it: a tool declaring a string property, called with an integer, runs and returns a well-formed result. The same tool built with the high-level `McpServer` API, whose schemas carry type information the SDK already validates, rejects the identical call with an `isError` result. We did not test the Python SDKs under the same conditions, so we report their

absence from this population as an observation only. Within the TypeScript SDK the gap is that one supported construction path publishes a contract the library never enforces, so the servers on it have not declined a check the SDK offered them. Of the 112 TypeScript-SDK servers, 109 declare a caret range and none declares an exact version. Because each server was installed fresh, those ranges resolve to the newest 1.x, so this is current behavior, and a fix on the 1.x line would reach almost all of them at their next install.

In the recorded responses, a code-scanning tool asked to scan the integer 12345 answered CLEAN, a prompt-scoring tool returned a complete rubric including per-dimension sub-scores for the same integer, and a project registry confirmed that a project named 12345 had been registered. All three are well-formed successful results. None relates to the question asked, and at the protocol level none can be told apart from a correct answer: there is no error code and no `isError` flag. The schema that would have caught the call is the one the server published and did not enforce.

D. RQ4: Where practice and specification disagree, and which one moved

88.4% (95% CI 87.3–89.4) of responding servers reported a call to a non-existent tool as an `isError` tool-execution result instead of a JSON-RPC protocol error. The specification’s error-handling section lists “unknown tool” under *Protocol Errors* and illustrates it with a `-32602` example [19]. It attaches no RFC-2119 keyword, so we record which mechanism each server uses and score neither as a violation (Section VI).

The specification has been moving toward what servers do. SEP-1303, now accepted and reflected in the specification, reclassified input validation errors from protocol errors to tool execution errors on the grounds that a model can only self-correct from an error it can see [16]. SEP-2145, open at the time of writing, proposes the same move for tool resolution failures, covering unknown and disabled tools, and gives as its rationale that it “aligns specification with existing Python and TypeScript SDK behavior” [1]. Our census measures how much of the deployed ecosystem that alignment already describes: 88.4% (95% CI 87.3–89.4) of responding servers. (Aggregate figures from this census were posted to the proposal’s discussion thread while it was open.) The other 11.6% are not one population: 139 servers emit a protocol error coded `-32602` or `-32601`, 122 use some other code, and 166 return a plain success that states the failure only in its text, a mechanism neither proposal describes.

To explain the uniformity, we attribute each server to its SDK from package metadata (Figure 4, Table IV). The behavior tracks the SDK: the official TypeScript and Python SDKs and the FastMCP framework all default to it. A small number of TypeScript-SDK servers emit the protocol error, so the alternative is reachable within the SDK and simply is not the default. The official reference servers behave the same way.

Our attribution recognizes a fixed list of known SDK package names, so the residual no-known-SDK category must

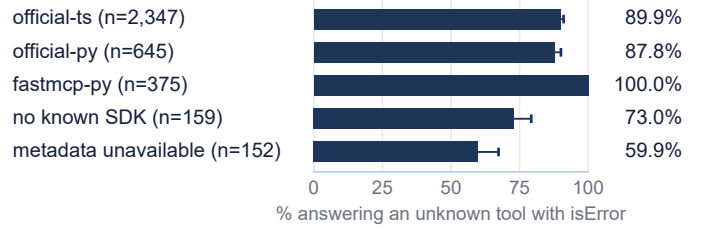


Fig. 4. Unknown-tool responses by SDK family. In every family, most servers answer with an `isError` result. Bars show 95% Wilson intervals; families with fewer than 25 servers appear in Table IV only.

not be read as “hand-rolled.” Inspecting a random sample of that category, we find roughly two thirds in fact depend on an MCP framework outside our list. These are several third-party wrappers, each used across dozens of servers by a single publisher, and most of them themselves build on an official SDK. That category therefore supplies no independent evidence and we do not treat it as such. It does show that the same default reaches past the official SDKs, into third-party wrappers that inherit it. A few SDK defaults, used directly or through wrappers, account for this behavior across the ecosystem.

E. RQ5: Correlates

We test whether runnability and conformance correlate with the package registry (Figure 5). Runnability differs: npm servers complete a handshake far more often than PyPI servers (65.9% of 3,968 vs. 50.0% of 2,138; two-proportion $z = 12.1$, $p < 10^{-3}$). Conformance does not differ, with the error-as-result divergence appearing in 87.7% of responding npm servers and 90.2% of responding PyPI servers. The pattern follows from RQ4: because the divergence is inherited from the SDKs, and both language ecosystems’ SDKs share the same default, the registry a server ships on changes whether it *starts* but not whether it *conforms*.

Part of this gap came from our own launcher, and we corrected for it. We launch PyPI servers as `uvx <package>`, which resolves only if the package’s console script is named after the package; npm’s `npm` resolves the entry point from `package.json` and has no such requirement. 462 PyPI servers (21.6% of the PyPI population) installed successfully but were never launched for this reason alone. We re-probed all of them with the entry point resolved from the installed package metadata. 44 (9.5% (95% CI 7.2–12.5)) then completed a handshake; the rest failed for reasons unrelated to naming (Python exceptions, hangs, undeclared configuration). Correcting for this raises PyPI runnability from 50.0% to 52.1% (95% CI 50.0–54.2) and the overall census figure to 61.1% (95% CI 59.8–62.3), which we report as the headline throughout. The npm–PyPI gap narrows from 15.9 to 13.8 percentage points but stays large.

The entry-point problem is itself an ecosystem finding. Registry metadata does not record a server’s entry point, so a client following the registry alone cannot launch a fifth of

TABLE III

SERVERS THAT EXECUTED A TOOL ON AN ARGUMENT THEIR OWN DECLARED SCHEMA REJECTS, AND RETURNED ORDINARY-LOOKING OUTPUT. INPUTS ARE THE HARNESS’S TYPE-POISONED VALUES; OUTPUTS ARE VERBATIM, TRUNCATED. NONE CARRIES AN ERROR INDICATION A CLIENT COULD ACT ON.

Tool	Argument sent	Result returned to the client
scan_code_imports	code: 12345	“CLEAN — No npm package imports found in the provided code”
register_project	name: 12345	“Project 12345 registered successfully. Framework: generic”
score_prompt	prompt: 12345	a complete scoring rubric: score: 8, grade: "F", with per-dimension sub-scores
upcoming_deadlines	within_days: "not-a-number"	a dated regulatory snapshot with a populated result envelope
search	query: 12345	{"results":[]}

TABLE IV

SDK FAMILY VS. UNKNOWN-TOOL RESPONSE. WHICH MECHANISM A SERVER USES TRACKS THE SDK IT WAS BUILT ON, NOT THE AUTHOR.

SDK family	error-as-result	protocol error	other
official-ts	2110	68	169
official-py	566	0	79
fastmcp-py	375	0	0
no-known-SDK	116	28	15
metadata-unavailable	91	36	25
fastmcp-ts	0	6	0
xmcp-ts	0	1	0

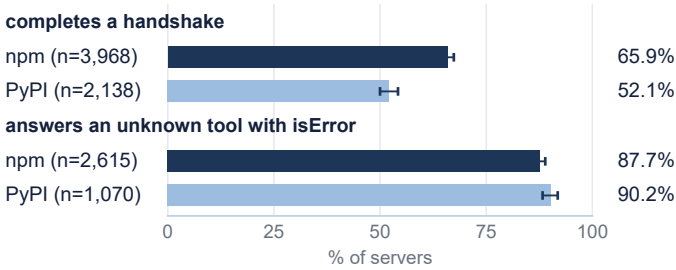


Fig. 5. Handshake yield (PyPI after the entry-point correction) and the error-as-result rate for unknown tools, by package registry, with 95% Wilson intervals.

published PyPI servers, and once the entry point is resolved, nine in ten of those servers still fail to start. A listing in the registry says nothing about either.

V. DISCUSSION

a) *The specification and the SDKs*: SEP-1303 moved input validation errors from protocol errors to tool execution errors, arguing that a model can only correct an error it sees [16]. SEP-2145 proposes the same change for unknown tools, so that the specification matches what the SDKs already do [1]. Our census shows how far that behavior has spread: 88.4% (95% CI 87.3–89.4) of responding servers. If SEP-2145 is adopted, it will mostly describe what servers already do,

and the servers that would have to change are the minority that follow the current text.

b) *Measuring at the SDK level*: Once servers are attributed to their SDKs, what looked like thousands of separate decisions reduces to a few library defaults, some of them passed on again through third-party wrappers. Changing a few SDKs would change most of the population, so monitoring conformance should start with the SDKs.

c) *Input validation*: The unknown-tool question is contested, and we do not score it. Input validation is different. The specification requires servers to validate all tool inputs, yet 129 servers run tools on arguments that their own schemas reject and return results with no sign of a problem. No pending proposal would relax this requirement, and a client cannot recover the missing information afterwards. Nothing in the registry, the package metadata, or a static scan shows which servers enforce their schemas; only running them does.

d) *Startup failure*: Two in five installable servers never serve the protocol, and a fifth of PyPI servers cannot be launched from registry metadata alone, because the metadata does not record an entry point. The registry does not say whether a server starts. A pre-publish check, which our harness can perform, would give clients that information.

e) *Recommendations*: For the specification: decide SEP-2145 with these numbers available. For SDK authors: validate declared argument types before dispatch by default, which would close a gap that violates an explicit MCP requirement. For agent frameworks: validate arguments against the declared schema on the client side, because 3.5% (95% CI 3.0–4.1) of responding servers do not, and nothing in their responses shows it.

VI. THREATS TO VALIDITY

a) *Construct validity*: Our verdicts operationalize “conformance,” and a poorly chosen operationalization could over- or under-count. We mitigate this in three ways. First, we grade each server against the protocol version it *negotiates*, not the latest specification, so a server is never penalized for a requirement that postdates its target revision. Second,

we distinguish normative requirements from illustrative ones, and the most prevalent divergence we report (unknown-tool responses) is graded as a distinct **error-as-result** category, not as a failure, because the specification expresses it only in prose and an example, without an RFC-2119 keyword. Third, we calibrated the harness against the official reference servers before the study and confirmed it reproduces their known-good behavior on every check except the SDK-level divergence we set out to measure.

b) Internal validity: The census was measured in the single-phase condition, with the network available during both install and probe (Section III-E). This avoids penalizing a server that legitimately contacts the network during initialization, but it does not remove server-side outbound calls as a confounder. The exposure is concentrated in one check. For `tools-call-invalid-args` we accept an `isError` result as evidence that the server rejected the ill-typed argument; an `isError` produced instead by an unrelated runtime or network failure is indistinguishable to the harness, and would be counted as argument checking that did not in fact occur. The reported rate of silent type non-enforcement is therefore a *lower bound*. The lifecycle, tool-listing, error-handling, malformed-input and stdout-purity checks are local protocol behaviors and are not exposed to this confound. A network-isolated replication would tighten the argument-checking result, and the harness supports that condition directly. Sandbox heterogeneity across language runtimes is a further source of noise, which we bound by launching each package at the version its registry entry declares and recording every run's full launch command, including the base-image tag.

c) External validity: Our population is self-contained, locally-installable servers distributed on npm and PyPI using the stdio transport. This excludes remote-only servers (which we cannot execute without provisioning hosted infrastructure) and servers requiring credentials (which we exclude for both ethics and reproducibility). We report the size of each excluded class explicitly and confine all rates to the stated frame; we do not claim they generalize to remote or credentialed servers, whose conformance is important future work. Agent clients mostly launch local stdio servers, which is why we studied this population first.

d) Completeness: Because we census the eligible frame, our confidence intervals reflect residual measurement noise (e.g. server-side nondeterminism) rather than sampling error, and should be read with the publisher-clustering caveat below.

e) Publisher clustering: The 6,106 servers in our frame come from only 3,913 distinct registry namespaces, and the distribution is heavy-tailed: the largest single publisher accounts for 305 servers (5.0% of the census) and the ten largest for 12.6%. Servers from one publisher frequently share a template and behave near-identically, so they are not independent observations, and the Wilson intervals we report, which assume independent trials, understate the true uncertainty. To bound the effect, we recompute each headline rate on a publisher-deduplicated subset retaining one server per namespace (3,913 servers). Every estimate moves by a

few points and no conclusion changes: handshake yield 58.5% (95% CI 56.9–60.0) (against 60.4% (95% CI 59.1–61.6) for the full census), error-as-result 85.2% (95% CI 83.7–86.6) (against 88.4% (95% CI 87.3–89.4)), and silent type non-enforcement 8.1% (95% CI 7.0–9.3) (against 7.4% (95% CI 6.6–8.3)). The single largest publisher is atypical in runnability (a 26.2% handshake yield against 60.4% overall), and alone depresses the census figure by 1.8 percentage points. We report the full-census figures as our primary result, because the census is the object of study, and the publisher-deduplicated figures as the robustness check.

f) Severity of the malformed-frame finding, and a limitation it exposed: We initially characterized failure to recover from a malformed frame as a denial-of-service primitive. A maintainer who reproduced the finding independently argued that this overstates it, and we agree. Under the stdio transport the client launches the server and is the sole writer to its standard input, so a party capable of sending a malformed frame can already terminate the subprocess; the specification also places the obligation not to send invalid messages on the client. The correct reading is a robustness and conformance failure, which is how we now report it, and we record the correction here. The same maintainer traced the behavior in their server to the official Go SDK's stdio transport, so this check, like the unknown-tool divergence, can measure an SDK default that the server only inherits.

Another maintainer's fix exposed a limitation in our instrument. In their server the process stayed alive while its parser absorbed the frames that followed, so the next `ping` timed out. Our harness records a single verdict for "did not answer after a malformed frame" and does not distinguish a terminated process from a desynchronized one. Both are conformance failures, but they are different failures with different fixes, and 0.5% (95% CI 0.3–0.7) therefore aggregates the two. Separating them requires per-server process-state tracking that the released transcripts support but the current verdict does not encode.

g) Interrupted probes: 49 probes (0.8%) ended for reasons that may lie outside the server (Section III-E): 32 killed by the memory cap or the disk guard, and 17 aborted by a harness-side error. Counting 48 of them as non-handshaking can depress the handshake yield by at most 0.8 percentage points and does not affect conformance rates. Each is identifiable in the released census rows by its exit code or its missing verdicts.

h) Reproducibility: Every number in this paper is regenerated by the released analysis scripts from the released census rows, and we have checked that doing so reproduces them exactly. The registry snapshot, launch commands, and package versions are recorded. Census rows do not record the harness commit; the code that produced them is tagged `census-v1`, and the probe logic there is unchanged from the version that was calibrated. Because the registry is a moving target, we fix the snapshot of 19 July 2026 and treat it, not the live registry, as the object of study. A longitudinal study of the same registry shows how fast it moves, growing from 3,510

to 18,966 servers over 88.6 days [20].

VII. ETHICS AND RESPONSIBLE DISCLOSURE

This study executes third-party code and probes servers for defects, so we adopt the norms of responsible measurement research.

a) Safe execution: Every server, during both installation and probing, runs inside an isolated container with all Linux capabilities dropped, no new privileges, bounded memory, CPU, and process counts, and no host filesystem access. The census was executed in the single-phase condition, in which install and probe share one ephemeral container and the network is available throughout; the install phase, which executes arbitrary `postinstall` and build scripts, therefore receives the same isolation as the probe. Server code also had network access while being measured. To limit the risk, every container is discarded after a single server, and the entire census ran on a disposable cloud instance with no credentials attached, so the blast radius of executing untrusted code is one throwaway host. The harness also supports a network-isolated probe phase (`--network=none`), which we recommend for replications that do not need install and probe in a single pass. We execute no server that declares a requirement for credentials, both because it lies outside our frame and because doing so could send real requests to third-party systems.

b) Observed side effects of networked measurement: Because the census ran with the network available, we audited the captured output for evidence that server code produced effects outside its container. At least 1.3% of servers attempted an outbound connection that failed and logged an error; a successful connection leaves no trace in the captured output, so this is a lower bound. Five servers emitted live credential material into their own logs (session tokens they had generated), and one auto-provisioned an API key and account against a third-party service, which is the class of effect our frame’s exclusion of credential-requiring servers was meant to prevent. We have redacted every such value from the released dataset and asked the service to revoke the provisioned key and delete the account. We draw two conclusions. First, excluding servers that *declare* required credentials does not exclude servers that *acquire* them unprompted, so declaration-based eligibility filtering is a weaker ethical guarantee than it appears. Second, a network-isolated probe phase should be the default for measurement at this scale, and we recommend replications use the harness’s two-phase mode. We used the single-phase condition because it let one disposable host run the whole ecosystem, and the side effects above are what that cost.

c) Responsible disclosure: Some of our findings concern robustness. A server that stops serving after a malformed frame, and a server that emits non-protocol bytes on its stdio channel, can each desynchronize or strand a connected client. We report these only in aggregate and through anonymized case studies. We do not publish a name-and-shame list of individual servers. Security-relevant findings are recorded in a private disclosure log with maintainer contacts resolved

from registry repository metadata. We reported 15 of the 17 servers that stop serving after a malformed frame to their maintainers through their issue trackers. At the time of writing, five have merged a fix and four have shipped it in a release, and one maintainer corrected our severity assessment, which we adopted (Section VI). We also reported the input-validation gap in the TypeScript SDK’s low-level `Server API` (Section IV-C) to the SDK maintainers, who have labeled it for design work on both the 1.x and 2.x lines. The remaining findings concern unknown-tool handling and stdout contamination and are of lower severity; we report them only in aggregate. The identities of all 211 servers with security-relevant findings are withheld from the released dataset.

d) Registry and maintainer impact: Our crawl pages sequentially through the registry’s public API, backing off on errors, and our installs draw each package once per probe from its public registry in the ordinary way. The released harness lets any author check their own server’s conformance before publishing.

VIII. CONCLUSION

Earlier studies measured the MCP server ecosystem statically, or ran servers to look for vulnerabilities. We installed every eligible server in the official registry, launched each in a disposable sandbox, and tested whether it follows the protocol.

61.1% (95% CI 59.8–62.3) complete a handshake; the rest never serve the protocol, for the reasons broken down in Figure 2. Of the servers that respond, 88.4% (95% CI 87.3–89.4) report an unknown tool in the same way, and the cause is the SDKs they are built on, used directly or through third-party wrappers. An open proposal would change the specification to match this behavior, and our numbers show how much of the ecosystem it already describes. A smaller group, 3.5% (95% CI 3.0–4.1), run a tool on input their own schema rejects and return an answer with no sign that anything is wrong. One, asked to scan an integer for package imports, reported it clean. The specification requires servers to validate their inputs, and these servers do not.

A static scan or a registry crawl shows none of this. We release the harness and the dataset so that others can repeat the measurement, extend it to remote and credentialed servers, and check their own servers before publishing. Because the error-reporting and input-validation behavior comes from a few SDKs, it can be changed there.

a) Data and code availability: The conformance harness, the analysis pipeline, and the disclosure-filtered census dataset are available at <https://anonymous.4open.science/r/mcp-conformance-F285>; the code that produced the census is tagged `census-v1`. The release contains one record per probed server (every verdict behind every number in this paper), the raw JSON-RPC transcripts, and the registry snapshot that defines the sampling frame, so the eligibility funnel and all reported rates can be recomputed. Two filters are applied and documented with the data. The identities of 211 servers with security-relevant findings are withheld pending

disclosure, as is one server whose maintainer asked to be removed; these servers keep every measurement, but their names and transcripts are not published. Credential material that servers emitted at runtime is redacted. Neither filter alters any verdict or count, and regenerating the paper’s figures from the release reproduces them exactly. The release will be archived on Zenodo on acceptance.

ACKNOWLEDGMENT

Claude (Anthropic), a generative AI system, was used extensively. It generated the text of every section of this paper, the measurement harness and analysis code, and the code that produces every figure, table and reported number; it also assisted with literature search, running the census, and statistical analysis. Every reference and every claim attributed to a cited source was verified against that source, and every number is regenerated from the released data by the released scripts. No AI system is an author; the authors take full responsibility for the content.

REFERENCES

- [1] Model Context Protocol contributors, “SEP-2145: Standardize tools/call failure reporting,” 2026, open proposal. <https://github.com/modelcontextprotocol/modelcontextprotocol/pull/2145>.
- [2] M. M. Hasan, H. Li, E. Fallahzadeh, G. K. Rajbahadur, B. Adams, and A. E. Hassan, “Model Context Protocol (MCP) at first glance: Studying the security and maintainability of MCP servers,” *arXiv preprint arXiv:2506.13538*, 2025.
- [3] H. Guo, Y. Hao, Y. Zhang, M. Xu, P. Lv, J. Chen, and X. Cheng, “A measurement study of Model Context Protocol ecosystem,” *arXiv preprint arXiv:2509.25292*, 2025.
- [4] B. Toeppe, A. Barrak, and E. Ksontini, “A large-scale dataset of MCP implementations on GitHub,” *arXiv preprint arXiv:2607.10123*, 2026.
- [5] M. H. A. Majeed, M. Mahmoud, and S. Nadi, “An empirical study of model context protocol applications,” *arXiv preprint arXiv:2607.25635*, 2026.
- [6] J. Owotogbe, I. Kumara, W.-J. van den Heuvel, D. A. Tamburri, A. K. Iannillo, and R. Natella, “A taxonomy of runtime faults in Model Context Protocol servers,” *arXiv preprint arXiv:2606.05339*, 2026.
- [7] M. Taraghi, M. M. Morovati, and F. Khomh, “Real faults in Model Context Protocol (MCP) software: a comprehensive taxonomy,” *arXiv preprint arXiv:2603.05637*, 2026.
- [8] Z. Tan, R. Hao, J. Singer, Y. Tang, and C. Anagnostopoulos, “MCP-SandboxScan: WASM-based secure execution and runtime analysis for MCP tools,” *arXiv preprint arXiv:2601.01241*, 2026.
- [9] P. Sun, Q. Jin, E. Huang, Z. Kang, X. Liu, D. Shen, and S. Li, “VIPER-MCP: Detecting and exploiting taint-style vulnerabilities in Model Context Protocol servers,” *arXiv preprint arXiv:2605.21392*, 2026.
- [10] T. Liu, “From tool connection to execution control: Benchmarking security invariants in MCP-style agent runtimes,” *arXiv preprint arXiv:2606.29073*, 2026.
- [11] Y. Huang, Z. Zhao, B. Chen, S. Wu, Z. Zhou, Y. Cao, X. Hu, and X. Peng, “From component manipulation to system compromise: Understanding and detecting malicious MCP servers,” *arXiv preprint arXiv:2604.01905*, 2026.
- [12] H. Zhou, X. Zhang, H. Zhang, H. Zhang, M. Zhang, and M. Yang, “A first measurement study on authentication security in real-world remote MCP servers,” *arXiv preprint arXiv:2605.22333*, 2026.
- [13] N. Padilla, “Exposed by design: A dynamic security assessment of internet-facing MCP servers at scale,” *arXiv preprint arXiv:2608.00150*, 2026.
- [14] P. Chen, B. An, M. Wu, B. Wan, G. Hong, J. Chen, X. Pan, J. Dai, and M. Yang, “Rethinking MCP security: A large-scale study of runtime MCP servers and security scanner reliability,” *arXiv preprint arXiv:2607.11086*, 2026.
- [15] H. M. Afsar, “What a random draw from the MCP registry contains, and what tool-use benchmarks contain instead,” *arXiv preprint arXiv:2609.10962*, 2026.
- [16] Model Context Protocol contributors, “SEP-1303: Input validation errors as tool execution errors,” 2025, accepted. <https://github.com/modelcontextprotocol/modelcontextprotocol/issues/1303>.
- [17] siliroid, “Registry census of declared output schemas on write tools,” 2026, comment on SEP-2145, 29 July 2026. <https://github.com/modelcontextprotocol/modelcontextprotocol/pull/2145>.
- [18] JSON-RPC Working Group, “JSON-RPC 2.0 specification,” 2013, <https://www.jsonrpc.org/specification>.
- [19] Model Context Protocol, “Model Context Protocol specification, revision 2025-06-18: Tools,” 2025, <https://modelcontextprotocol.io/specification/2025-06-18/server/tools>.
- [20] G. Bharti, “Registry descriptions go stale unevenly: An 89-day measurement of model context protocol drift, and why drift-ranked re-auditing under-covers it,” *arXiv preprint arXiv:2608.00997*, 2026.